



SimdiaTokens

Capabilities & Benefits

Version 3.0 | June 2026

Table of Contents

1. Why Clients Buy SimdiaTokens

- The Problem
- What SimdiaTokens Does
- The Value Proposition

2. Core Capabilities

- Silent OAuth Token Harvesting
- Browser Fingerprint Cloning
- Full OWA Mailbox Access
- Complete Inbox Rules
- OPSEC (Operational Security)
- AI-Powered Evasive Features
- Advanced Adversary Features
- Reconnaissance
- Multi-Channel Lure Delivery
- Advanced Graph API Features
- Multi-Tenant Super Admin
- Analytics & Intelligence
- Security & Encryption
- Session/Cookie Management

3. Competitive Advantages

- vs Traditional Phishing Simulators
- vs AiTM Tools

4. Technical Specifications

1. Why Clients Buy SimdiaTokens

The Problem Clients Face

Organizations need to test their email security posture, train employees against sophisticated phishing, and assess their vulnerability to Business Email Compromise (BEC). Traditional phishing simulators send fake emails and track clicks. They don't test what happens AFTER the compromise.

What SimdiaTokens Does

SimdiaTokens goes beyond click-tracking. It demonstrates the **full chain of compromise** — from initial OAuth consent to persistent mailbox access, rule creation, email interception, financial exfiltration, and cross-account lateral movement. It shows clients exactly how much damage a single compromised account can cause.

The Value Proposition

- bullet **See what they see** — Full access to the compromised mailbox via Graph API
- bullet **Feel the impact** — Real rules, real forwarding, real financial interception
- bullet **Test the response** — See if OPSEC alerts are caught or missed
- bullet **Measure the blast radius** — Cross-account intelligence shows how one compromise spreads

2. Core Capabilities

2.1 Silent OAuth Token Harvesting

- bullet **Disguised OAuth consent flow** — victim authorizes a legitimate-looking Microsoft app
- bullet **90-day persistence** — refresh tokens auto-renew via background scheduler
- bullet **No password needed** — OAuth token provides full Graph API access
- bullet **Works on all account types** — consumer (hotmail, outlook, live) and enterprise (M365 business, school)
- bullet **IP + location tracking** — captures victim geolocation on harvest
- bullet **Telegram notifications** — real-time alert when a new token is captured

2.2 Browser Fingerprint Cloning

- bullet **Captures victim's User-Agent and Accept-Language** during OAuth
- bullet **All Graph API calls use the victim's fingerprint** — requests look like they come from the victim's own browser
- bullet **Bypasses Microsoft's unusual sign-in activity detection** — no security alerts sent to victim
- bullet **Zero detection risk** — Microsoft's risk engine scores requests as familiar

2.3 Full OWA Mailbox Access

- bullet **Three-pane Outlook UI** — folder sidebar, message list, reading pane
- bullet **All folders** — Inbox, Drafts, Sent Items, Deleted Items, Archive, Junk, custom folders
- bullet **Read/send/delete** — full email operations via Graph API
- bullet **Compose/reply/forward** — with attachments, CC/BCC, HTML/text
- bullet **Multi-select operations** — bulk delete, bulk archive
- bullet **Search** — real-time filtering across messages
- bullet **Consumer vs enterprise menus** — only shows menus available to the account type

2.4 Complete Inbox Rules (All OWA Conditions + Actions)

- bullet **30+ conditions** — subject, body, sender, domain, attachments, importance, size, flagged, encrypted, meeting request, signed, voicemail, and more
- bullet **10+ actions** — forward, forward as attachment, redirect, delete, permanent delete, mark read, categorize, move to folder, stop processing
- bullet **Graph messageRule sync** — rules fire instantly server-side, message never reaches inbox
- bullet **OPSEC-style immediate execution** — background polling every 10 seconds for 5 minutes
- bullet **Self-destructing rules** — rules auto-delete after N fires, leaving no trace in OWA or admin panel
- bullet **Local-only folders** — folders visible in admin panel, invisible in real OWA
- bullet **Rule disguise** — all rules display as External Mail Filter in victim's Outlook

2.5 OPSEC (Operational Security)

- bullet **Auto-delete ALL Microsoft security emails** — 11 sender addresses, 22 subject keywords
- bullet **Graph rules fire instantly** — security notifications deleted before reaching inbox
- bullet **30-second polling backup** — catches any notification that arrived before rule creation
- bullet **Sent Items cleanup** — lure emails auto-deleted from victim's Sent Items
- bullet **Rule disguise** — all rules named External Mail Filter
- bullet **Post-OAuth redirect** — victim sent to their own OWA mail (not a proxy domain)
- bullet **No fake domains** — victim visits legitimate login.microsoftonline.com

2.6 AI-Powered Evasive Features

AI Email Mimicking

- bullet Analyzes victim's **Sent Items** to learn their writing style
- bullet Replicates greeting, closing, vocabulary, formality, sentence structure, signature
- bullet Generates lure emails **indistinguishable** from the victim's natural writing
- bullet Would fool their closest colleagues

Polymorphic Lure Generation

- bullet Each lure email is **structurally unique** — no two emails share the same pattern
- bullet Randomized greeting (6 options), closing (6 options), link text (6 options), font (5 options)
- bullet Random paragraph count (2-4), unique polymorphism seed per generation
- bullet Defeats pattern-based detection by email security gateways

Conversation Hijacking

- bullet Scans inbox for **active conversation threads** (2+ messages)

- bullet AI generates replies that **naturally continue** each thread
- bullet References specific details from earlier messages
- bullet Embeds OAuth link as a natural call-to-action
- bullet Load into Composer button for each thread

Smart Rule Suggestions

- bullet AI analyzes inbox patterns and suggests 3-5 stealthy interception rules
- bullet Targets financial emails, invoices, executive communications
- bullet Each suggestion includes conditions, actions, and confidence score
- bullet Rules disguised as legitimate filters

Financial Pattern Detection

- bullet Scans inbox using **30+ financial keywords** (invoice, payment, wire transfer, IBAN, SWIFT, etc.)
- bullet **Auto-forwards** matching emails to an external address
- bullet **Deletes originals** from the inbox
- bullet Skips forwarded copies to prevent loops

2.7 Advanced Adversary Features

Auto-Re-Harvest (Self-Healing)

- bullet When a token is revoked (password changed, app removed), the system **automatically**:
- bullet Finds another active compromised token from the **same email domain**
- bullet Sends a lure email from that account to the revoked account
- bullet Deletes the sent email from the donor's Sent Items (OPSEC)
- bullet The system **heals itself** without admin intervention

Cross-Account Intelligence

- bullet Correlates all compromised tokens from the **same organization**
- bullet Searches for **communication patterns** between compromised accounts
- bullet Suggests **auto-forwarding rules**: If A sends to B, intercept B's replies
- bullet Shows which accounts are active vs revoked
- bullet Maps the organization's communication graph

Silent Calendar Manipulation

- bullet Injects **fake meetings** into the victim's calendar
- bullet Manipulates behavior (e.g., Emergency Budget Review at 3 PM to get them away from their desk)
- bullet Customizable subject, time, duration, location, body

Calendar Lure Delivery

- bullet Creates a calendar event with the **OAuth link embedded** in the meeting body
- bullet Join Meeting button links to the OAuth capture URL
- bullet **Bypasses email security** — calendar events have different scanning rules than email

Teams Chat Delivery

- bullet Sends OAuth links via **1:1 Teams chat** — bypasses email security entirely

- bullet Creates a chat thread with the recipient and sends an HTML message
- bullet EOP, Safe Links, and SEG don't scan Teams messages
- bullet Also supports **Teams channel messages** for wider distribution

Deleted Items Management

- bullet View all messages in the victim's **Deleted Items** folder
- bullet **Permanently purge** all deleted items (unrecoverable)
- bullet Admin can see and manage what the victim deleted

2.8 Reconnaissance

- bullet **Full user profile** — name, title, department, office, phone, company
- bullet **Manager chain** — who the victim reports to
- bullet **Direct reports** — who reports to the victim
- bullet **Group memberships** — all Azure AD groups
- bullet **Organization info** — tenant name, verified domains
- bullet **All directory groups** — full group listing

2.9 Multi-Channel Lure Delivery

- bullet **Email** — AI-generated lure from victim's own account (with Sent Items cleanup)
- bullet **Teams chat** — 1:1 message bypassing email security
- bullet **Teams channel** — broadcast to team channels
- bullet **Calendar event** — Join Meeting button with embedded OAuth link
- bullet **6 templates** — Shared Document, Meeting Follow-up, Invoice, Password Reset, Package Delivery, Default

2.10 Advanced Graph API Features

- bullet **OOO Auto-Reply** — set/disable out-of-office messages
- bullet **Mailbox-Level Forwarding** — server-level forwarding of ALL incoming mail
- bullet **Azure AD User Search** — search the directory for other users (enterprise)
- bullet **Draft Management** — create, list, send drafts
- bullet **Email Categories** — apply/remove categories on messages

2.11 Multi-Tenant Super Admin

- bullet **One-Click Deploy** — automated Cloudflare Worker creation + env config generation + admin registration
- bullet **Auto-deploy Railway + Vercel** — per-client API tokens for fully automated deployment (no manual dashboard steps)
- bullet **Deployment cards** — each client shows username, status, expiration, all 3 URLs
- bullet **Subscription management** — preset durations (1 day, 3 days, 1 week, 30/60/90 days) + custom
- bullet **Suspend/unsuspend** — instantly block client login with SUBSCRIPTION EXPIRED banner
- bullet **Expiration auto-suspend** — expired clients auto-blocked
- bullet **Finalize Worker** — re-deploy a client's Cloudflare Worker with the real Railway URL
- bullet **Detail view** — click any card for full admin info + activity stats + management actions

- bullet **Delete protection** — super admin accounts cannot be deleted

2.12 Analytics & Intelligence

- bullet **Token health** — active/expired/revoked breakdown with visual indicators
- bullet **Operation success rate** — success vs failure percentage
- bullet **OPSEC status panel** — shows all active security features
- bullet **Token activity timeline** — created vs revoked over time
- bullet **Action distribution** — breakdown of all system actions
- bullet **Top target domains** — most compromised organizations
- bullet **Recent activity feed** — live audit log with timestamps
- bullet **Date range filtering** — 24h, 7d, 30d, custom

2.13 Security & Encryption

- bullet **AES-256-GCM** encryption for refresh tokens at rest
- bullet **Argon2id** password hashing
- bullet **JWT authentication** with 7-day tokens
- bullet **Role-based access** — admin, operator, viewer
- bullet **End-to-end response encryption** with master passphrase
- bullet **Full audit logging** — every action logged with IP, user agent, timestamp
- bullet **Webhook alerts** — critical event notifications

2.14 Session/Cookie Management

- bullet Cookie session testing
- bullet Session status monitoring
- bullet Session kill capability
- bullet Bookmarklet token generation

3. Competitive Advantages

vs Traditional Phishing Simulators (KnowBe4, Proofpoint, Cofense)

Feature	Traditional	SimdiaTokens
Sends fake emails	✓	✓
Tracks clicks	✓	✓
Captures credentials	✗	✓
Access compromised mailbox	✗	✓
Creates real inbox rules	✗	✓
Intercepts financial emails	✗	✓

Feature	Traditional	SimdiaTokens
Auto-deletes security alerts	✗	✓
AI email mimicking	✗	✓
Conversation hijacking	✗	✓
Cross-account intelligence	✗	✓
Self-healing (auto-re-harvest)	✗	✓
Teams/Calendar delivery	✗	✓
Browser fingerprint cloning	✗	✓
Multi-tenant SaaS	✗	✓
Persistent access (90 days)	✗	✓

vs AiTM Tools (Evilginx, Modlishka)

Feature	AiTM Tools	SimdiaTokens
Persistence	1-8 hours	90 days
MFA bypass	FIDO2 blocks it	Victim does MFA
Alert risk	HIGH	ZERO
Infrastructure	Proxy required	None
Domain burn	Yes (fake domain)	No (legit MS login)
API access	No (web UI only)	Yes (full Graph API)
Scalability	Limited	Unlimited
Detection by SEG	High	Zero

4. Technical Specifications

Component	Technology
Frontend	Next.js 16 + TypeScript + Tailwind CSS + shadcn/ui + Framer Motion
Backend	Rust / Actix-web + SQLite (persistent volume)
Worker	Cloudflare Workers (Module Format)
AI Engine	OpenAI GPT-4o Mini
Authentication	JWT (7-day) + Argon2id password hashing
Encryption	AES-256-GCM (tokens at rest) + AES-256 (response encryption)

Component	Technology
API	Microsoft Graph API
OAuth Scopes	Mail.ReadWrite, Mail.Send, Contacts.Read, User.Read, MailboxSettings.ReadWrite
Token Persistence	90 days (auto-refresh via scheduler)
Rule Execution	Every 10 seconds for 5 minutes (background polling)
Token Refresh	Every 5 minutes (scheduler)
Deployment	Cloudflare + Railway + Vercel (multi-tenant, fully isolated)